



AIBOS

AI Business Operating System: multitenant business
management platform with an AI Copilot

Part A · System Documentation

Part B · Software Requirements Specification (IEEE 830 / ISO 29148)

Version 0.1.0 · Prepared August 12, 2026

github.com/IlyasMoro/ai-business-os

Companion diagrams: claude.ai/code/artifact/f6ad9942...

Contents

1. Brand & Visual Identity	3
2. System Completeness Assessment	5
3. Executive Summary	6
4. Technology Stack	7
5. Architecture	8
6. Data Model	9
7. Modules	10
8. Use Cases	11
9. Current As Is Process Flows	14
10. Security	15
11. Risk & Mitigation Register	16
12. Billing & Subscriptions	18
13. Deployment & Infrastructure	19
14. Testing	20
15. Appendix: Changes Made This Session	21
B1. Introduction	22
B2. Overall Description	23
B3. External Interface Requirements	25
B4. System Features (Functional Requirements)	26
B5. Other Nonfunctional Requirements	31
B6. Appendices	33

1. Brand & Visual Identity

1.1 Wordmark

The AIBOS wordmark is a plain, bold, tight tracked text lockup: not a badge, pill, or bordered card. Earlier iterations wrapped it in a bordered/backdrop blurred “glass badge”; that treatment has been removed everywhere (sidebar, mobile nav, and all five auth pages) in favor of the same flat text style the marketing site always used, for visual consistency across the whole product.

- On dark surfaces (app shell, auth pages): solid Blue 400 text.
- On the marketing hero: a white to slate 400 gradient fill for extra weight against the headline.
- Font weight: extrabold, tracking tight (condensed letter spacing) at all sizes.

1.2 Color Palette

AIBOS uses a dark first, glass morphic palette: true black backgrounds, near black elevated surfaces, hairline borders, and a single blue accent: plus three semantic colors reserved for subscription/status states.

Swatch	Hex	Name	Usage
	#000000	True black	Marketing & auth page background: full bleed, not a dark gray
	#0A0A0A	Near black (dropdown)	Floating menu/dropdown surfaces
	#111111	Near black (card)	Dashboard cards, panels
	#60A5FA	Blue 400	Wordmark, links, primary accent on dark backgrounds
	#3B82F6	Blue 500	Accent fills at low opacity (badges, icon chips)
	#2563EB	Blue 600	Wordmark / links on light backgrounds
	#F8FAFC	Slate 50	Primary text on dark surfaces
	#94A3B8	Slate 400	Secondary / muted text
	#34D399	Emerald 400	Active / success state (subscription active)
	#FBBF24	Amber 400	Trial / warning state (days remaining)
	#F87171	Red 400	Past due / error state

1.3 Surface & Elevation Language

- Backgrounds: true black (#000) on marketing/auth; near black card surfaces (#111111) inside the authenticated app shell.
- Borders: hairline, low opacity white (white/[0.06] to white/10): never a solid gray/black border.
- Glass effect: backdrop blur md paired with a translucent white fill (white/[0.03] to white/10) on floating chips, badges, and dropdowns.

- Corners: rounded xl (cards, buttons) to rounded 2xl (larger panels).
- Light mode: a parallel light: variant set (slate 50 background, slate 900 text, slate 200 borders) is maintained throughout the authenticated app shell; marketing/auth pages are intentionally dark only.

1.4 Iconography & Type

- Icon set: lucide react, stroke based, used at 14 to 20px inline with text.
- Body type: system sans stack via Tailwind's default font stack; no custom webfont is loaded.
- Monospace: used for the pricing figure (\$49/mo) and stat numbers on the landing page, for a data plate feel.

2. System Completeness Assessment

Verdict: AIBOS is functionally complete for its intended scope: a single tenant per company, all in one SMB business platform with an AI Copilot. Every module has real CRUD and real business logic (not stubs), tenant isolation has been audited end to end, and the test suite is substantial. A short list of concrete, verified gaps remains before this is fully production hardened for paying customers at scale: none of them architectural, all independently fixable.

Area	Status	
Core CRUD: all 15 modules	Complete	
Multi tenancy & session auth	Complete	
Tenant isolation (companyId scoping)	Complete	
AI Copilot (read + human approved write)	Complete for its 6 defined action types	
Billing (Stripe Checkout/Portal/webhooks)	Complete	
Automation rule logic + concurrency lock	Complete	
Automation scheduling	Gap	logic exists but nothing triggers it automatically; “Run now” is manual only
Data backup / export	Gap	no backup or export capability exists
Legal pages (Terms / Privacy)	Gap	still contain the literal placeholder “[Company Legal Name]”
Per company logo / white labeling	Not built	roadmap item, not urgent for direct SMB use
Automated testing (unit + e2e)	Complete	86 unit tests, 14 e2e spec files
CI/CD	Complete	lint, typecheck, unit, build, and e2e all run on every push
Production hosting	Complete	live on Railway

3. Executive Summary

AIBOS (AI Business Operating System) is a multi tenant business management platform: every company that signs up gets its own isolated workspace covering CRM, Inventory, Sales, Invoicing, Accounting, HR, Payroll, Projects, Support, Marketing, Procurement, Calendar, and Documents: all sharing one underlying data model: plus an AI Copilot that can look up live data and propose actions a human must approve before anything changes.

Positioning: AIBOS sits in the same category as lightweight all in one SMB business software (Odoo, Zoho One) rather than enterprise ERP (SAP, NetSuite): no manufacturing/MRP, no multi currency consolidation, no heavy customization framework. Its differentiator versus that category is the AI Copilot's human approved action model, not deployment scale.

Pricing: a single flat plan at \$49/month with a 14 day free trial, billed via Stripe. Access is automatically gated once a trial expires or a subscription lapses.

4. Technology Stack

- Framework: Next.js 16 (App Router, Server Actions as the primary write path)
- Language: TypeScript throughout, React 19
- Database: PostgreSQL via Prisma 7 (@prisma/adapters-pg)
- Styling: Tailwind CSS 4
- Validation: Zod on every Server Action / form
- AI: Groq (Llama 3.3 70B Versatile) for the AI Copilot's tool calling chat
- Payments: Stripe (Checkout Sessions + Billing Portal + webhooks)
- Email: Resend, with a runtime configurable API key/from address via Platform Settings
- OAuth: Google (Gmail send as integration)
- Auth: jose (JWT session cookies), bcryptjs (password hashing)
- Testing: Vitest (unit) + Playwright (end to end, one spec file per module)
- Hosting: Railway (web service + managed Postgres); a Vercel project is linked but not the active production host

5. Architecture

Full visual diagrams for this section (request/data flow, tenant isolation, AI approval state machine, billing gate, actor/use case map) are published separately and referenced below and on the title page: diagrams are not embedded in this file so they remain interactive and independently updatable.

<https://claude.ai/code/artifact/f6ad9942-7doe-4ea6-b042-88c8ee212360>

5.1 Multi Tenancy Model

Every tenant owned table carries a `companyId` foreign key back to `Company`, with `onDelete: Cascade` so deleting a company cleanly removes all of its data. Tenant isolation is convention based rather than structural: each `Server Action` explicitly filters its `Prisma` queries by the calling session's `companyId` (directly, or via a nested relation filter through the immediate parent for child records like `Task` or `TicketMessage` that have no `companyId` column of their own).

5.2 Server Actions Pattern

Writes go through `src/lib/actions/<module>.ts` `Server Actions` (marked "use server"), each of which: authenticates via `verifySession()/requireRole()`, validates input with a `Zod` schema from `src/lib/validation/<module>.ts`, re verifies that every referenced foreign key belongs to the caller's company, performs the mutation, and calls `revalidatePath()` for any affected route.

5.3 Session & Roles

Sessions are signed JWTs (jose, HS256) stored in an `httpOnly`, `secure`, `sameSite=lax` cookie, valid for 7 days, carrying `userId`, `companyId`, `role`, `name`, and `email`. Three roles exist per company: `OWNER` (the signup account, full access including billing and payroll), `ADMIN`, and `EMPLOYEE`. A separate "Platform Admin" capability is gated by the `PLATFORM_ADMIN_EMAIL` environment variable rather than a database role, specifically so it cannot be granted or escalated from inside the app itself.

5.4 AI Copilot Architecture

The AI Assistant (`src/lib/ai.ts` + `src/lib/ai tools.ts`) runs a bounded tool calling loop (max 4 iterations) against `Groq`. Tools are split into two trust tiers:

- Read tools (`summarize_sales`, `forecast_next_month_revenue`, and `lookups`) execute immediately and only return data already visible in the product.
- Write tools (create a task, change a ticket's status/priority, change a customer's status, draft an invoice, email an overdue payment reminder) never execute directly: they insert a `PENDING AiAction` row for a human with `OWNER/ADMIN` role to approve or reject.

Every proposed action is validated against the calling company before being stored, and re validated again at execution time in every branch of `executeAiAction` (one branch, `CREATE_TASK`, was found missing that second check during this session's audit and has since been fixed).

6. Data Model

35 Prisma models across the domains below. Full field level detail lives in `prisma/schema.prisma`, which carries inline documentation comments explaining non obvious design decisions.

Domain	Models
Tenancy & Auth	Company, User, TeamInvite, PasswordResetToken, RateLimitHit, AuditLog
CRM	Customer, Contact
Inventory	Product
Procurement	Supplier, PurchaseOrder, PurchaseOrderItem
Sales	Order, OrderItem
Invoicing	Invoice, InvoiceLineItem
Accounting	Transaction
HR & Payroll	Employee, PayrollRun, PayrollItem
Projects	Project, Task, TaskComment
Support	Ticket, TicketMessage
AI Assistant	AiChatMessage, AiAction
Documents	Document
Automation	AutomationSettings, RunLock
Integrations	GoogleIntegration
Marketing	Campaign
Calendar	CalendarEvent
Billing	Subscription
Platform (super admin)	PlatformSettings

7. Modules

Module	What it does
CRM & Sales	Customer records (LEAD/ACTIVE/INACTIVE status), contacts, and orders in one pipeline, optionally linked to a marketing campaign.
Inventory	Products with cost, unit price, stock quantity, and a per product reorder level; low stock is flagged the moment quantity dips below it.
Procurement	Suppliers and purchase orders; marking a PO “Received” automatically increments the ordered products' stock quantity.
Invoicing	Line items, a per company default or per invoice tax rate, and an automatically computed total; one click send with an automatic overdue reminder via Automation.
Accounting	Income/expense transactions, optionally tied back to the invoice or project that generated them, feeding the revenue/expense trend charts.
HR & Payroll	Employee records and payroll runs; each payroll item computes net pay from gross pay minus deductions.
Projects	Projects, tasks (TODO/IN_PROGRESS/DONE, LOW/MEDIUM/HIGH priority), and threaded task comments.
Support	Customer support tickets with staff/customer message threads, priority, and status.
Marketing	Campaigns with a channel, budget, and date range, linkable to the customers they generated.
Calendar	Company wide events feeding the dashboard's upcoming agenda widget.
Reports	Six month trend, KPI tiles, and status breakdowns across every module, plus an AI generated summary.
Automation	Four background toggles: overdue invoice reminders, low stock reorder alerts, stale ticket escalation, and dead lead cleanup.
Integrations	Google OAuth (Gmail) connection for sending company email through the user's own mailbox.
Documents	File uploads (max 8MB) attached to a Customer, Invoice, Ticket, Project, Campaign, or Employee record.
AI Assistant	Chat interface with tool calling: read tools run immediately, write tools require explicit human approval before executing.

8. Use Cases

Nine representative use cases covering every actor and the platform's core mechanisms. IDs are stable references for future traceability (e.g. test plans, tickets).

UC1 Register a Company & Start Trial

Actor(s): Prospective Owner **Trigger:** Submits the /register form

Preconditions: The email is not already registered to an account.

MAIN FLOW

- Enter company name, name, email, and password.
- System validates the input with Zod.
- System creates Company, Subscription (TRIALING, trialEndsAt = +14 days), and User (role OWNER) in a single transaction.
- A session is created and the browser is redirected to /dashboard.

ALTERNATE / EXCEPTION FLOW

If the email already exists, a generic error is shown and no account is created.

Postconditions: *A new isolated tenant workspace exists with an active 14 day trial.*

UC2 Invite a Team Member

Actor(s): Owner or Admin **Trigger:** Clicks “Invite” on /dashboard/team

Preconditions: The requester holds the OWNER or ADMIN role.

MAIN FLOW

- Enter the invitee's email and intended role.
- System creates or updates a TeamInvite with a hashed, 7 day expiring token.
- An email with the invite link is sent.
- The invitee opens the link, sets their name and password.
- A User is created with the invited role and a session is started.

ALTERNATE / EXCEPTION FLOW

If the email fails to send, the inviter sees an error (the token remains valid for retry). If the invite was already accepted, a generic “invalid or expired” message is shown.

Postconditions: *The new team member has access scoped to their assigned role.*

UC3 Create and Send an Invoice

Actor(s): Owner, Admin, or Employee **Trigger:** “New invoice” on /dashboard/invoicing

Preconditions: At least one Customer record exists.

MAIN FLOW

- Select the customer, due date, and tax rate.
- Add one or more line items.
- The total is computed automatically (quantity × unit price, plus tax).
- Click “Send”.
- An email is sent to the customer and status changes to SENT.

ALTERNATE / EXCEPTION FLOW

If the customer has no email on file, sending is blocked with an inline error before anything happens.

Postconditions: *The invoice is visible to the customer by email; once past its due date, it becomes eligible for the automatic overdue reminder (if Automation is enabled and run).*

UC4 Receive a Purchase Order & Restock

Actor(s): Owner, Admin, or Employee **Trigger:** Marks a PurchaseOrder “Received”

Preconditions: The purchase order has at least one line item.

MAIN FLOW

- Change the PO's status to RECEIVED.
- System stamps receivedAt.
- For every item on the PO, the corresponding Product's stockQty is incremented by the ordered quantity, inside one database transaction.

Postconditions: *Inventory levels reflect the restock; the PO is marked received.*

UC5 Ask the AI Copilot a Question or Propose an Action

Actor(s): Any signed in user **Trigger:** Sends a chat message in /dashboard/assistant

Preconditions: The user is under the rate limit (30 messages/hour).

MAIN FLOW

- The message is stored and the rate limit is checked.
- Groq is called with a live business data snapshot and the available tool definitions.
- Read tools (forecasts, summaries, lookups) execute immediately and the answer is shown in the chat.
- Write tools instead create a PENDING AiAction and the assistant tells the user it is awaiting approval.

ALTERNATE / EXCEPTION FLOW

If Groq returns a malformed tool call, the turn falls back to a plain answer instead of failing outright. If the rate limit is exceeded, the user is told to wait.

Postconditions: *Either an answer appears in the chat, or a PENDING proposal appears in the Assistant tab for an Owner/Admin to decide on.*

UC6 Approve or Reject an AI Proposed Action

Actor(s): Owner or Admin **Trigger:** Reviews a PENDING AiAction card

Preconditions: The action's status is still PENDING.

MAIN FLOW

- (Approve) Click Approve.
- `executeAiAction()` re validates that the target record still belongs to the company.
- The underlying write (create task, update ticket, etc.) runs.
- Status becomes EXECUTED, or FAILED with the error recorded if it throws.

ALTERNATE / EXCEPTION FLOW

(Reject) Click Reject: status becomes REJECTED and nothing executes.

Postconditions: *The action's full audit trail (status, decider, timestamp) is permanent and visible.*

UC7 Run a Payroll Cycle

Actor(s): Owner or Admin **Trigger:** Creates a new PayrollRun for a pay period

Preconditions: At least one active Employee exists.

MAIN FLOW

- Create a PayrollRun (status DRAFT) for a period start/end.
- Add a PayrollItem per employee with gross pay and deductions; net pay is computed automatically.
- Mark the run PROCESSED, then PAID.

Postconditions: *Payroll history is recorded per employee; the run's total reflects the sum of its items.*

UC8 Subscribe or Manage Billing

Actor(s): Owner (billing is Owner only) **Trigger:** Visits /dashboard/billing

Preconditions: N/A

MAIN FLOW

- (Subscribe) Click “Subscribe”, complete Stripe Checkout.
- On success, a webhook sets Subscription to ACTIVE.
- (Manage) Click “Manage billing” to open the Stripe Billing Portal and update the card or cancel.

Postconditions: *Subscription status reflects Stripe's record; dashboard access follows directly from it.*

UC9 Platform Admin Removes a Company

Actor(s): Platform Admin (env var gated, not a role) **Trigger:** Confirms deletion on /dashboard/admin/[companyId]

Preconditions: The signed in email matches the PLATFORM_ADMIN_EMAIL environment variable.

MAIN FLOW

- Type the company's exact name to confirm.
- The company: and everything cascading from it: is permanently deleted.

Postconditions: *All of that company's data is gone. This is irreversible (see Risk R3).*

9. Current As Is Process Flows

The step sequences below describe how each core business process actually runs today, traced directly from the Server Action / automation code, not from an idealized design.

9.1 Lead to Cash

Customer created (status LEAD) → [optional] linked to a Campaign → Order created → OrderItems added (unit price snapshot from Product at time of adding) → Invoice created for the order → Line items added, tax applied, total computed automatically → Invoice sent (status → SENT) → Customer pays, staff sets status → PAID → Transaction (INCOME) automatically booked in Accounting

9.2 Procure to Pay / Restock

Product stock drops to/below reorderLevel → Automation “Low stock reorder” creates a draft PurchaseOrder against the earliest added Supplier (only if enabled and run): or staff creates one manually → PurchaseOrderItems added → PO marked RECEIVED → Stock quantities incremented, PO total computed

Note: this automation only fires when a company toggles it on AND someone (or a future scheduler) triggers a run: see Risk R1.

9.3 Support Ticket Lifecycle

Ticket created (OPEN, linked to a Customer, optional Employee assignee) → Staff/customer messages exchanged → Priority/status updated as work progresses → [if Automation “Stale ticket escalation” has run] tickets open >48h auto escalate to HIGH priority → Resolved → CLOSED

9.4 AI Action Proposal & Approval

Chat message sent → Tool call selected by the model → Read tool: immediate answer / Write tool: PENDING AiAction created → Owner/Admin reviews the proposal → Approve → executeAiAction() rechecks companyId → EXECUTED or FAILED / Reject → REJECTED

Full state diagram: see the companion Diagrams page, section 03.

9.5 Payroll Run Lifecycle

PayrollRun created (DRAFT, period start/end) → PayrollItems added per employee (netPay = grossPay – deductions) → Run total recomputed automatically → Status → PROCESSED (processedAt stamped) → Status → PAID

9.6 Subscription Lifecycle

Signup → TRIALING (14 days) → Stripe Checkout success → ACTIVE / trial ends with no checkout → dashboard blocked except /billing → Renewal fails → PAST_DUE (blocked) → Owner cancels via Billing Portal → CANCELED (blocked)

Full state diagram: see the companion Diagrams page, section 04.

10. Security

10.1 Authentication

- Passwords hashed with bcrypt; never stored or logged in plaintext.
- Per account lockout after 5 failed login attempts (15 minute cooldown), plus per IP rate limiting on login/signup/password reset for the no such account case where no per account counter exists yet.
- Password reset and team invite tokens are single use, SHA 256 hashed at rest, and time limited (1 hour and 7 days respectively).

10.2 Tenant Isolation

See Section 5.1 and the companion diagrams (section 02). Verified this session by reading every mutating query in all 20 action files against the tenant model it touches.

10.3 Findings From This Session's Audit

- `executeAiAction`'s `CREATE_TASK` branch did not re verify that the target `projectId` belonged to the calling company at execution time (every sibling branch did). Fixed by adding the same check used elsewhere in the file.
- `removeTeamMember`'s delete call relied solely on an earlier, separately scoped lookup rather than carrying its own `companyId` filter: the only delete across the whole codebase that didn't self guard. Fixed by adding the filter directly to the delete's where clause.
- Session claims (role, `companyId`) are trusted from the JWT for its full 7 day lifetime with no per request database re check: a deliberate performance/staleness tradeoff, noted as a design characteristic rather than a defect (see Risk R6).

10.4 Platform Level Access

Platform Settings (app wide email credentials) and the company deletion admin tool are gated by `requirePlatformAdmin()`, which checks the signed in user's email against `PLATFORM_ADMIN_EMAIL`: an environment variable, not a database flag.

11. Risk & Mitigation Register

Twelve risks identified this session, verified against the actual codebase rather than assumed.

Likelihood/impact are qualitative (Low/Medium/High); business only items (R11, R12) are marked: since they're not technical risks.

ID	Risk	Category	Likelihood	Impact	Mitigation / Status
R1	Automation never fires without a manual click: no scheduler triggers it	Operational	Medium	Medium	Add a scheduled trigger (Railway cron / GitHub Actions schedule) calling the existing runAutomations(); the logic and its distributed lock (RunLock) are already built.
R2	No data backup or export capability	Data continuity	Medium	High	Add scheduled Postgres backups (confirm Railway's managed retention policy) and/or an in app export feature.
R3	Company deletion is instant, cascading, and irreversible	Data loss	Low	High	Typed name confirmation already required; consider an export before delete step or a soft delete window.
R4	Terms of Service / Privacy Policy contain a literal placeholder, [Company Legal Name]	Legal / compliance	High (live now)	Medium/High	Replace with the real legal entity name; have counsel review before onboarding paying customers.
R5	Tenant isolation is a coding convention, not DB enforced (no Postgres RLS)	Security	Low (audited)	Critical if it slips	Audited this session across all 20 Server Action files; 2 gaps found and fixed. Recommend cross tenant assertion tests or RLS as a structural backstop.
R6	Session claims trusted from the JWT for its full 7 day life; no per request DB re check	Security	Low	Medium	Deliberate performance tradeoff; consider a shorter TTL or a fresh check on role sensitive actions if this becomes a concern.
R7	Single AI provider (Groq); no fallback on a full outage	Availability	Low	Medium	Chat already degrades to a visible error message rather than crashing; no secondary model provider is configured.

ID	Risk	Category	Likelihood	Impact	Mitigation / Status
R8	Rate limiting is implemented as DB rows (RateLimitHit), not an in memory/edge store	Performance / cost	Low today	Low/Medium	Adequate at current scale; migrate to a dedicated store (e.g. Redis) if traffic grows materially.
R9	AI proposes an incorrect or unwanted action	AI / operational	Medium (LLMs err)	Low (mitigated)	Mitigated by design: every write requires explicit Owner/Admin approval before it executes; nothing the AI does is irreversible without a human step.
R10	Third party outage (Stripe, Resend, Google, Groq)	Availability	Low/Medium	Medium	Each integration is already wrapped in try/catch with graceful degradation in the code paths reviewed this session.
R11	Flat single pricing tier (\$49/month)	Business	N/A	N/A	Deliberate simplicity for launch; revisit if customer segments diverge.
R12	No per company logo / white labeling	Product / market fit	N/A	N/A	Roadmap item; not required for direct SMB self serve customers.

12. Billing & Subscriptions

Every new company gets a Subscription row created transactionally at signup with status `TRIALING` and a `trialEndsAt` 14 days out. `checkSubscriptionAccess()` blocks the entire dashboard (except the billing page itself) once that date passes, unless the company has since gone `ACTIVE` via Stripe Checkout.

Subscription states: `TRIALING`, `ACTIVE`, `PAST_DUE`, `CANCELED`. Billing is managed through Stripe Checkout (subscribe) and the Stripe Billing Portal (manage/cancel), with webhook driven status sync at `/api/webhooks/stripe`.

13. Deployment & Infrastructure

- Source: github.com/IlyasMoro/ai-business-os, branch master.
- Hosting: Railway project “ai-business-os”, service “web”, deployed via `railway up`.
- Database: managed PostgreSQL on Railway.
- CI: GitHub Actions runs npm audit, the Vitest suite, and a production build on every push, plus a full Playwright e2e run against a real Postgres service container.
- Environment: DATABASE_URL, JWT_SECRET, NEXT_SERVER_ACTIONS_ENCRYPTION_KEY, GROQ_API_KEY, RESEND_API_KEY/FROM, PLATFORM_ADMIN_EMAIL, APP_BASE_URL, GOOGLE_CLIENT_ID/SECRET, STRIPE_SECRET_KEY/PRICE_ID/WEBHOOK_SECRET.

14. Testing

- Unit tests: Vitest, 86 tests across 11 files under `src/lib/`, covering validation, math (invoice totals, payroll net pay, purchase order totals), and access control helpers.
- End to end: Playwright, one spec per module (14 spec files) plus shared fixtures, global setup/teardown, and DB cleanup scripts.
- Static checks: ESLint and `tsc --noEmit`, both required to pass cleanly before any change in this session was considered done.

15. Appendix: Changes Made This Session

For traceability, the following changes were made and deployed to production during the session this document was produced in:

- Removed the badge/card styling from the AIBOS wordmark across the sidebar, mobile nav, and all five auth pages, matching the landing page's plain text treatment.
- Relocated the account menu (avatar, name, sign out) from the topbar into a footer row at the bottom of the sidebar/mobile nav; recolored the avatar from amber to blue glass.
- Removed the logo from the landing page footer and centered the copyright line.
- Rewrote the landing page's hero headline and all six module descriptions to state specific, verified product behavior instead of generic filler; fixed a duplicated “Payroll” tag; added a hover glow to the secondary module tag list.
- Removed the “Welcome back” heading from the login page.
- Consolidated the company/subscription status widget: replaced the topbar's bare company badge and a separately duplicated dashboard body card with a single `CompanyStatusBadge` in the topbar.
- Ran a full `companyId` tenant isolation audit across all 20 Server Action files; found and fixed two defense in depth gaps (Section 10.3).
- Reset the “Event Me” company's trial period after it had expired.
- Produced this document and its companion diagram set, including the completeness assessment, risk register, use cases, and as is process flows.

PART B

Software Requirements Specification

Structured per IEEE 830 / ISO-IEC-IEEE 29148

Derived from the current implementation, August 12, 2026

This Part is self contained and uses its own B prefixed numbering, per convention for an SRS appended to a broader documentation set. Every requirement below reflects code read directly from the repository this session: none are aspirational unless explicitly marked as a gap and cross referenced to the Part A risk register.

B1. Introduction

B1.1 Purpose

This specification defines, as a set of verifiable requirements, the behavior AIBOS's implementation currently exhibits. It exists to give engineering, QA, and any future contributor a single authoritative, testable reference for what the system does: distinct from Part A, which explains how and why.

B1.2 Document Conventions

Requirement IDs follow FR<group>.<n> (functional) and NFR<group>.<n> / BR<n> (non functional / business rule). "Shall" denotes a mandatory, verifiable requirement; a requirement marked (gap) describes intended behavior not yet implemented, cross referenced to its Part A Risk ID.

B1.3 Intended Audience and Reading Suggestions

Engineers implementing or modifying AIBOS should read B4 (System Features) and B5 (Nonfunctional Requirements) against the module they're touching. QA/test authors should use B6.2 (Traceability Matrix) to map requirements to use cases. Reviewers assessing production readiness should start at B5.3 (Security) and the gap marked requirements throughout B4 through B5.

B1.4 Product Scope

AIBOS is a multi tenant, web based business management platform covering CRM, Inventory, Procurement, Sales, Invoicing, Accounting, HR, Payroll, Projects, Support, Marketing, Calendar, Documents, Reporting, and Automation, unified by one data model per company and augmented by an AI Copilot restricted to read access plus human approved write proposals. It excludes manufacturing/MRP, multi currency consolidation, and per company custom branding.

B1.5 References

- Part A of this document (System, Brand & Governance Documentation)
- Companion diagrams: <https://claude.ai/code/artifact/f6ad99427doe4ea6bo4288c8ee212360>
- prisma/schema.prisma (authoritative data model, inline documented)
- IEEE Std 830 (1998), Recommended Practice for Software Requirements Specifications
- ISO/IEC/IEEE 29148:2018, Systems and software engineering: Life cycle processes, Requirements engineering

B2. Overall Description

B2.1 Product Perspective

AIBOS is a new, self contained, cloud hosted product: not an extension of an existing system and not one component of a larger suite. Each company is a fully isolated tenant sharing one application deployment and one database, distinguished entirely by companyId.

B2.2 Product Functions

See Part A, Section 7 (Modules) for the full function catalog; it is not repeated here to avoid drift between two descriptions of the same behavior.

B2.3 User Classes and Characteristics

- OWNER: the signup account; full access including billing and team removal; no assumed technical sophistication.
- ADMIN: day to day management access to every module including HR/Payroll and AI action approval, excluding billing and team removal.
- EMPLOYEE: day to day module use only; no administrative or approval capability.
- Platform Admin: the product operator; one individual, gated by an environment variable rather than a per company role; scoped to platform wide administration only.
- AI Copilot: a system actor, not a human user; may read any data in its calling company and propose writes, but cannot execute a write itself.

B2.4 Operating Environment

Client: any modern evergreen browser (Chromium, Firefox, Safari), desktop and mobile viewports.

Server: Node.js runtime under Next.js 16 (App Router). Database: PostgreSQL 16 compatible. Hosting: Railway, region sfo (San Francisco).

B2.5 Design and Implementation Constraints

- Writes are implemented as Next.js Server Actions, not a separate REST/GraphQL API layer.
- Data access is exclusively through Prisma; no raw SQL outside generated queries.
- Tenant isolation is enforced in application code (per query companyId filters), not via database level row security.
- Exactly one subscription price point exists; no tiering logic.
- The AI provider is fixed to Groq's hosted Llama 3.3 70B Versatile model; no multi provider fallback.

B2.6 User Documentation

In app UI copy and empty states are the primary end user guidance; no separate user manual exists outside this technical documentation set.

B2.7 Assumptions and Dependencies

- Assumes continuous availability of four third party services: Stripe (billing), Resend (email), Groq (AI inference), and Google OAuth (Gmail send as).
- Assumes Railway's managed Postgres provides adequate durability; no independent backup is currently layered on top (Risk R2).
- Assumes all traffic arrives over HTTPS; no additional transport security requirement is enforced in application code beyond what the hosting platform terminates.

B3. External Interface Requirements

B3.1 User Interfaces

A responsive, server rendered web UI: a persistent left sidebar on desktop (collapsing to a drawer on mobile), dark first visual theme with a maintained light mode variant, described fully in Part A Section 1.

B3.2 Hardware Interfaces

None. The system has no direct hardware interface and runs entirely as a hosted web application.

B3.3 Software Interfaces

- Stripe API: subscription billing (Checkout Sessions, Billing Portal, webhooks).
- Resend API: transactional email.
- Groq API: AI chat completion and tool calling.
- Google OAuth 2.0 / Gmail API: connected account email sending.
- PostgreSQL wire protocol: via Prisma's adapter-pg.

B3.4 Communications Interfaces

All client server communication occurs over HTTPS. Stripe delivers asynchronous billing events via a signature verified HTTPS webhook to `/api/webhooks/stripe`.

B4. System Features (Functional Requirements)

Grouped by feature area, in the same order as Part A Section 7. Each requirement is independently verifiable against the running application.

B4.1 Authentication & Account Management

ID	Requirement
FR1.1	The system shall allow a prospective customer to register a new company workspace with a company name, personal name, email, and password.
FR1.2	The system shall reject registration using an email already associated with an existing account.
FR1.3	The system shall hash all passwords with bcrypt before storage.
FR1.4	The system shall lock a user account for 15 minutes after 5 consecutive failed login attempts.
FR1.5	The system shall rate limit login, registration, and password reset requests per source IP.
FR1.6	The system shall allow a user to request a password reset email containing a single use, 1 hour expiring, hashed token.
FR1.7	The system shall issue a signed session cookie (httpOnly, secure, sameSite=lax), valid for 7 days, upon successful authentication.

B4.2 Team & Role Management

ID	Requirement
FR2.1	The system shall allow a user with role OWNER or ADMIN to invite a new team member by email and assigned role.
FR2.2	The system shall email an invite link containing a single use, 7 day expiring, hashed token.
FR2.3	The system shall create a new user with the invited role once the invitee sets a name and password via a valid invite link.
FR2.4	The system shall allow an OWNER to remove a team member, provided the target is not the last remaining OWNER.
FR2.5	The system shall prevent a user from removing their own account via the team removal action.

B4.3 CRM & Sales

ID	Requirement
FR3.1	The system shall support creation, update, and deletion of Customer records with status LEAD, ACTIVE, or INACTIVE.
FR3.2	The system shall allow a Customer to be optionally linked to a Campaign.
FR3.3	The system shall allow creation of a Contact scoped to a Customer.

ID	Requirement
FR3.4	The system shall allow creation of an Order linked to a Customer, with one or more order items.
FR3.5	The system shall snapshot a product's unit price onto an order item at the time it is added.

B4.4 Inventory

ID	Requirement
FR4.1	The system shall support creation, update, and deletion of Product records with a SKU unique per company.
FR4.2	The system shall track stock quantity and a configurable reorder level per product.
FR4.3	The system shall flag a product as low stock once its quantity is at or below its reorder level.
FR4.4	The system shall prevent deletion of a product referenced by an existing order item.

B4.5 Procurement

ID	Requirement
FR5.1	The system shall support creation, update, and deletion of Supplier records.
FR5.2	The system shall allow creation of a Purchase Order linked to a Supplier, with one or more line items.
FR5.3	The system shall automatically increment the stock quantity of every ordered product when a Purchase Order's status changes to RECEIVED.
FR5.4	The system shall compute a Purchase Order's total automatically from its line items.

B4.6 Invoicing

ID	Requirement
FR6.1	The system shall allow creation of an Invoice linked to a Customer, with a due date and tax rate.
FR6.2	The system shall generate a unique, sequential invoice number per company.
FR6.3	The system shall compute an Invoice's total automatically from its line items and tax rate.
FR6.4	The system shall allow an Invoice to be emailed to its customer, provided the customer has an email on file.
FR6.5	The system shall record the timestamp of the last automated overdue reminder sent for an Invoice, to enforce a cooldown between reminders.

B4.7 Accounting

ID	Requirement
FR7.1	The system shall support creation, update, and deletion of income/expense Transaction records.
FR7.2	The system shall allow a Transaction to be optionally linked to the Invoice or Project that generated it.
FR7.3	The system shall automatically create an income Transaction when an Invoice's status changes to PAID.

B4.8 HR & Payroll

ID	Requirement
FR8.1	The system shall support creation, update, and deletion of Employee records.
FR8.2	The system shall prevent deletion of an Employee referenced by an existing Payroll Item.
FR8.3	The system shall allow creation of a Payroll Run for a defined pay period.
FR8.4	The system shall compute an employee's net pay automatically as gross pay minus deductions.
FR8.5	The system shall reject a Payroll Item where deductions exceed gross pay.
FR8.6	The system shall restrict Payroll actions to users with role OWNER or ADMIN.

B4.9 Projects

ID	Requirement
FR9.1	The system shall support creation, update, and deletion of Project records, optionally linked to a Customer.
FR9.2	The system shall allow creation of Tasks within a Project, with status (TODO/IN_PROGRESS/DONE) and priority (LOW/MEDIUM/HIGH).
FR9.3	The system shall allow threaded comments on a Task, attributed to the authenticated user.

B4.10 Support

ID	Requirement
FR10.1	The system shall allow creation of a Ticket linked to a Customer, with status, priority, and an optional assignee.
FR10.2	The system shall allow staff and customer messages to be appended to a Ticket's thread.
FR10.3	The system shall offer an AI suggested priority for a new ticket based on its subject and description.

B4.11 Marketing

ID	Requirement
FR11.1	The system shall support creation, update, and deletion of Campaign records with a channel, budget, and date range.
FR11.2	The system shall allow a Campaign to be linked to the Customers it generated.

B4.12 Calendar

ID	Requirement
FR12.1	The system shall support creation and deletion of company wide Calendar Events.
FR12.2	The system shall surface upcoming Calendar Events on the dashboard's agenda widget.

B4.13 Documents

ID	Requirement
FR13.1	The system shall allow a file up to 8MB to be uploaded and attached to a Customer, Invoice, Ticket, Project, Campaign, or Employee record.
FR13.2	The system shall verify that the target record belongs to the uploading user's company before accepting an upload.

B4.14 Reports

ID	Requirement
FR14.1	The system shall display six month revenue and expense trends on the dashboard overview.
FR14.2	The system shall display KPI tiles and status breakdowns across every module.
FR14.3	The system shall generate an AI written summary of the company's current business snapshot on request.

B4.15 Automation

ID	Requirement
FR15.1	The system shall allow an OWNER or ADMIN to independently toggle four automation rules: overdue invoice reminders, low stock reorder, stale ticket escalation, and dead lead cleanup.
FR15.2	The system shall send an automated reminder for an overdue Invoice no more than once per 24 hour cooldown period.
FR15.3	The system shall automatically raise a Purchase Order for any product at or below its reorder level, provided one is not already on order.
FR15.4	The system shall automatically raise the priority of an open Ticket to HIGH after 48 hours without resolution.
FR15.5	The system shall automatically mark a LEAD status Customer as INACTIVE after 30 days with no Order.
FR15.6	The system shall serialize automation runs per instance using a distributed lock, preventing concurrent execution.
FR15.7 (gap: R1)	The system shall trigger automation runs on a recurring schedule without manual action. Not yet implemented: execution is currently manual only via "Run automations now".

B4.16 Integrations

ID	Requirement
FR16.1	The system shall allow a user to connect a Google account via OAuth for sending company email from their own mailbox.
FR16.2	The system shall allow a connected Google integration to be disconnected.

B4.17 AI Assistant

ID	Requirement
FR17.1	The system shall provide a chat interface in which a signed in user can ask questions about their company's live data.
FR17.2	The system shall rate limit AI chat messages to 30 per user per rolling hour.
FR17.3	The system shall execute read only AI tool calls (lookups, forecasts, summaries) immediately without approval.
FR17.4	The system shall require explicit approval from a user with role OWNER or ADMIN before any AI proposed write action executes.
FR17.5	The system shall re validate that an AI proposed action's target record belongs to the approving user's company at the moment of execution.
FR17.6	The system shall record the outcome (EXECUTED, FAILED, or REJECTED) of every AI proposed action.

B4.18 Billing & Subscription

ID	Requirement
FR18.1	The system shall create a Subscription with status TRIALING and a 14 day trial period for every newly registered company.
FR18.2	The system shall block dashboard access, except the billing page, once a trial expires without an active paid subscription.
FR18.3	The system shall allow an OWNER to start a Stripe Checkout session to subscribe.
FR18.4	The system shall allow an OWNER to open the Stripe Billing Portal to update payment details or cancel.
FR18.5	The system shall synchronize Subscription status from Stripe webhook events.

B4.19 Platform Administration

ID	Requirement
FR19.1	The system shall restrict platform administration functions to the single user whose email matches the configured platform admin address.
FR19.2	The system shall permanently delete a company only after the Platform Admin re types its exact name as confirmation.
FR19.3	The system shall allow the Platform Admin to configure platform wide email sending credentials.

B5. Other Nonfunctional Requirements

B5.1 Performance

ID	Requirement
NFR1.1	The system shall serve every tenant scoped list/detail query filtered by an indexed companyId column.
NFR1.2 (gap)	No formal response time SLA or throughput benchmark is currently defined or measured.

B5.2 Safety (data integrity)

ID	Requirement
NFR2.1	The system shall never store a user's password in plaintext.
NFR2.2	The system shall never expose a password hash or any API secret to the client.
NFR2.3 (gap: R2)	The system shall provide a means to back up or export company data independent of the hosting provider's own database snapshotting. Not yet implemented.

B5.3 Security

ID	Requirement
NFR3.1	The system shall encode session identity only in a signed, httpOnly, secure cookie: never in client readable storage.
NFR3.2	The system shall verify a Stripe webhook's cryptographic signature before processing its payload.
NFR3.3	The system shall scope every tenant owned database query by the authenticated session's companyId.
NFR3.4	The system shall gate platform wide administrative functions by a deployment controlled environment variable rather than a database stored role.

B5.4 Software Quality Attributes

ID	Requirement
NFR4.1 (Maintainability)	The system shall enforce static type checking and schema validation on every Server Action before it executes.
NFR4.2 (Testability)	The system shall maintain automated unit coverage for validation/business math logic and end to end coverage for each module's primary workflow.
NFR4.3 (Portability)	The system's data layer shall target standard PostgreSQL without vendor specific extensions.

B5.5 Business Rules

ID	Requirement
BR1	A user's role (OWNER/ADMIN/EMPLOYEE) shall determine which Server Actions they may invoke; the check shall occur server side.
BR2	Only an OWNER may manage billing or remove a team member.
BR3	Only an OWNER or ADMIN may approve/reject an AI proposed action, manage Payroll, or invite team members.
BR4	A company with an expired trial and no active subscription shall retain access to the billing page only.

B6. Appendices

B6.1 Glossary

Term	Definition
Company / Tenant	One customer organization's isolated workspace; the unit of data isolation, keyed by companyId.
Server Action	A Next.js server side mutation function ("use server"), the primary write path in AIBOS: not a separate REST API.
AiAction	A database record of one AI Copilot proposed write, with a lifecycle of PENDING → EXECUTED/FAILED or REJECTED.
RunLock	A single row mutex used to prevent two Automation runs from executing concurrently.
Trial	The 14 day period after signup during which a company has full access without payment.
Platform Admin	The product operator; an env var gated capability (PLATFORM_ADMIN_EMAIL), not a database role, distinct from a company's OWNER.
Tenant Isolation	The practice of scoping every query to the caller's own company so no cross company data is ever returned.
Shall	Per IEEE 830/29148 convention, indicates a mandatory, verifiable requirement (as opposed to "should"/"may").

B6.2 Requirements Traceability Matrix

Maps each requirement group to where it's discussed in Part A and, where applicable, to a Use Case or Risk ID.

Requirement group	Feature area	Related Part A section / Use Case	Related Risk
FR1.x	Authentication & Account Management	Part A §5.3, §10.1 · UC1, UC2	N/A
FR2.x	Team & Role Management	Part A §7 · UC2, UC9	N/A
FR3.x	CRM & Sales	Part A §7, §9.1	N/A
FR4.x	Inventory	Part A §7, §9.2	N/A
FR5.x	Procurement	Part A §7, §9.2 · UC4	R1
FR6.x	Invoicing	Part A §7, §9.1 · UC3	N/A
FR7.x	Accounting	Part A §7, §9.1	N/A
FR8.x	HR & Payroll	Part A §7, §9.5 · UC7	N/A
FR9.x	Projects	Part A §7	N/A

Requirement group	Feature area	Related Part A section / Use Case	Related Risk
FR10.x	Support	Part A §7, §9.3	R1
FR11.x	Marketing	Part A §7	N/A
FR12.x	Calendar	Part A §7	N/A
FR13.x	Documents	Part A §7	N/A
FR14.x	Reports	Part A §7	N/A
FR15.x	Automation	Part A §7, §9.2 · gap FR15.7	R1
FR16.x	Integrations	Part A §7	N/A
FR17.x	AI Assistant	Part A §5.4, §7, §9.4 · UC5, UC6	R9
FR18.x	Billing & Subscription	Part A §12, §9.6 · UC8	R11
FR19.x	Platform Administration	Part A §10.4 · UC9	R3